STARWEAVER

Hands-On-Learning: Build Your Own Threat Model: STRIDE & DREAD in Action

Scenario

You've been asked to review a basic login system for a web application used by internal employees. Your task is to identify potential threats during the design phase and prioritize them for remediation. In this hands-on lab, you'll apply the STRIDE model to surface common threat types and use the DREAD model in Excel to score and rank each threat by severity.

Instructions

1. **Model the System in Draw.io or diagrams.net:**
   - Open diagrams.net.
   - Create a diagram representing a simple login system. Include:
     - A user/client
     - Login form
     - Web server
     - User database
     - Admin dashboard

Add labeled arrows for data flows (e.g., “Submit credentials,” “Authenticate user”).

2 **Apply STRIDE to Each Component:**

For each component and data flow, identify at least one applicable STRIDE threat type:

- S: Spoofing
- T: Tampering
- R: Repudiation
- I: Information Disclosure

- D: Denial of Service
- E: Elevation of Privilege
- Label each threat directly on your diagram using colored markers or text boxes (e.g., “S – Login could be spoofed”). Ensure each component has at least one threat type applied.

3 Transfer Threats into Excel for DREAD Scoring:

- Open the provided Excel DREAD template (or create a new sheet with columns: Threat, Damage, Reproducibility, Exploitability, Affected Users, Discoverability, Average Score).
- For each identified threat from your STRIDE diagram:
  - Enter it as a row in Excel.
  - Assign a score from 1–10 for each DREAD category.
  - Use =AVERAGE() to calculate the risk score.

4 Color-Code and Prioritize

- Apply conditional formatting:
  - Red = High (7–10)
  - Yellow = Medium (4–6)
  - Green = Low (1–3)
- Sort by risk score to identify top-priority threats.

This activity gives learners a chance to apply the lesson by:

- Practicing visual threat modeling using the STRIDE framework
- Converting identified threats into a prioritized, data-driven list using DREAD scoring
- Reinforcing structured, repeatable approaches for cyber risk identification and response

Instructions for Documenting and Sharing the Project for Peer Review

Document the Project

- Use a word processor (e.g., Word or Google Docs) to compile all materials into a single project report.
- Ensure clarity, structure, and that each required section is present.
- Edit for professionalism and business-appropriate tone.

Share the Project

- Save your full report and the PowerPoint slide as PDFs.
- Upload both files to the Peer Review area in the course platform.
- In your submission post, include a 2–3 sentence description of what you learned and what your report includes.

Peer Review

- Read at least two peer submissions.
- Provide constructive, respectful feedback on clarity, logic, visual effectiveness, and actionability.

By completing this project, you'll walk through the full cyber risk management process—from identification to executive communication. You'll reinforce your ability to use structured tools and techniques that translate technical risk into strategic action.